Rather than writing a dedicated key distribution server, it is also possible to distribute keys using an existing protocol such as OAuth2. A draft standard for OAuth2 (currently expired, but periodically revived by the OAuth working group) describes how to distribute encrypted symmetric keys alongside an OAuth2 access token (https://tools.ietf.org/html/draft-ietf-oauth-pop-architecture-08#section-7.1.1) and RFC 7800 describes how such a key can be encoded into a JSON Web Token (https://tools.ietf.org/html/rfc7800#section-3.3). The same technique can be used with CBOR Web Tokens (https://www.rfc-editor.org/rfc/rfc8747.html#name-representation-of-an-encryp). These techniques allow a device to be given a fresh key every time it gets an access token, and any API servers it communicates with can retrieve the key in a standard way from the access token itself or through token introspection. Use of OAuth2 in an IoT environment is discussed further in chapter 13.

12.4.3 Ratcheting for forward secrecy

If your IoT devices are sending confidential data in API requests, using the same encryption key for the entire lifetime of the device can present a risk. If the device key is compromised, then an attacker can not only decrypt any future communications but also all previous messages sent by that device. To prevent this, you need to use